

INCIDENT RESPONSE REPORT

INC-20260919-001

Organisation	TryHatMe Inc.
Classification	CLEAR – For Educational Purpose Only
Severity	CRITICAL
Analyst	Jovita Kusuma
Detection Date	2026-09-19
Report Date	2026-09-19
Status	ACTIVE INVESTIGATION

1. Executive Summary

On 2026-09-19, TryHatMe Inc. sustained a multi-stage intrusion attributed to an externally-staged threat actor. The attack chain progressed from a spear-phishing / SEO-poisoning lure that delivered a trojanised printer driver, through anti-forensic evasion, a rogue Active Directory account, command-and-control beaconing, Windows privilege-escalation reconnaissance, lateral movement via a poisoned network share, and ultimately targeted access to security-monitoring infrastructure including the SIEM dashboard.

Seven distinct attack stages were identified. The blast radius spans at least five Windows endpoints and the internal IT software share. Full containment and remediation are required before resuming normal operations.

2. Incident Timeline

Time (UTC)	Host / Actor	Event
07:21:10	win-3449 / Yani Zubair	Phishing email opened; browser navigated to beanie-print-driver.thm (178.92.53.38:80)
07:22:11	win-3449	Beanie-PrintDriver.exe downloaded and executed — payload deployed
07:22–07:38	win-3449	Anti-forensic commands: fake Windows Update service start + log wipe (PowerShell)
07:30–07:44	win-3454 / liam.espinoza	Rogue AD account liam.espinoza created; workstation win-3454 (10.1.3.129) activated
07:33–07:41	5 hosts	C2 beaconing established to 178.92.220.140:8090 (unknown-tcp protocol)
07:44:02	win-3454	Beanie-PrintDriver.exe executed on liam.espinoza machine (dropper stage)
07:45:39	win-3454	SharpUp.exe dropped to AppData\Local\Temp; 7 PrivEsc modules run through 07:47:12
07:52:33	win-3454 + 3 Sales hosts	CapitAll-Sales-Installer.exe executed from \\ITServe\Installers\ — lateral movement via poisoned share
07:55+	win-3449	HTTP access to siem.platform.com, security.tryhatme.com, inventory.tryhatme.com

3. Attack Stages & Technical Detail

Stage 01 — Initial Access — Phishing & SEO-Poisoning Delivery [T1566.001](#) · [T1189](#)

Patient Zero: Yani Zubair (win-3449, 10.1.3.194, IT dept) received a spear-phishing email at 07:21:10.

The email contained a link to a SEO-poisoned domain (beanie-print-driver.thm resolving to 178.92.53.38:80) disguised as a legitimate Beanie printer driver download page.

At 07:22:11 the user downloaded and executed Beanie-PrintDriver.exe, which served as the primary payload dropper for the entire campaign.

A secondary blocked URL (googl.com) was also attempted, suggesting a backup C2 or redirect chain.

Two external sender addresses were identified: oskar@hatemporium.com and buckley@gmail.com.

IoCs observed at this stage:

Type	Indicator
DOMAIN	beanie-print-driver.thm
DOMAIN	googl.com (blocked)
IP	178.92.53.38:80 (malware delivery)
EMAIL	oskar@hatemporium.com
EMAIL	buckley@gmail.com
FILE	Beanie-PrintDriver.exe (Downloads)

Stage 02 — Execution & Anti-Forensic Evasion [T1059.001](#) · [T1070.004](#)

Immediately after payload execution, a sequence of PowerShell commands were run under the liam.espinoza session context to masquerade malicious activity as legitimate Windows Update traffic.

Start-Service wuauclt — started the Windows Update service to blend network connections into normal update traffic.

wuauclt.exe /detectnow — legitimate Windows Update client used as a LOLBin to communicate outbound while appearing benign.

Remove-Item C:\Windows\Temp* -Recurse -Force — cleared the Temp directory to destroy forensic artefacts.

The wuauclt.exe process was spawned as a child of services.exe (normal), providing process-tree legitimacy while the payload ran under a separate thread.

IoCs observed at this stage:

Type	Indicator
CMD	Start-Service wuauclt
CMD	wuauclt.exe /detectnow /updatenow
CMD	Remove-Item C:\Windows\Temp* -Recurse -Force
FILE	wuauclt.exe (masqueraded LOLBin)

Stage 03 — Persistence — Rogue Active Directory Account [T1136.001](#)

The attacker created a rogue domain account (TRYHATME\liam.espinoza) to maintain persistent access independent of the initial payload.

The account was assigned to the Sales department and mapped to workstation win-3454 (10.1.3.129), a machine with no prior suspicious history.

This allowed the attacker to conduct subsequent stages (PrivEsc, lateral movement) under a seemingly legitimate user identity, evading user-account-based detection.

The rogue account first appeared in Sysmon telemetry at 07:30 and was actively used through the remainder of the observed attack window.

Correlated: multiple legitimate colleagues also opened MeetingNotes.docx around 07:43–07:46 — suggesting a possible spear-phish wave using an internal document lure.

IoCs observed at this stage:

Type	Indicator
ACCT	TRYHATME\liam.espinoza (rogue)
HOST	win-3454 — 10.1.3.129
HOST	win-3449 — 10.1.3.194 (Patient Zero)

Stage 04 — Command & Control — C2 Beaconing [T1571](#) · [T1095](#)

Five internal hosts established outbound C2 connections to 178.92.220.140 on non-standard port 8090 using a raw TCP protocol (unknown-tcp), not HTTP/HTTPS.

Beaconing was consistent and recurring — indicative of an automated implant check-in rather than manual operator activity.

The C2 server (178.92.220.140) is the same infrastructure block as the malware delivery server (178.92.53.38), confirming single-actor attribution.

Affected hosts: win-3449 (Patient Zero), win-3454 (rogue liam.espinoza), and three additional endpoints (10.1.3.27, 10.1.3.36, 10.1.3.66).

Non-standard port usage (8090) was chosen to avoid default firewall egress rules that block common C2 ports.

IoCs observed at this stage:

Type	Indicator
IP	178.92.220.140:8090 (C2 server)
HOST	10.1.3.129 (win-3454)
HOST	10.1.3.194 (win-3449)
HOST	10.1.3.27
HOST	10.1.3.36
HOST	10.1.3.66

Stage 05 — Privilege Escalation — SharpUp Recon [T1068](#)

At 07:44:02 Beanie-PrintDriver.exe executed on win-3454 (liam.espinoza), dropping SharpUp.exe into AppData\Local\Temp\.

SharpUp is a C# port of PowerUp — a well-known open-source Windows privilege-escalation enumeration tool.

Seven consecutive modules were executed between 07:45:39 and 07:47:12, each checking a different PrivEsc vector:

- AlwaysInstallElevated: checks if MSI packages can be installed as SYSTEM
- CachedGPPPassword: searches for Group Policy Preference cached credentials
- DomainGPPPassword: same check against domain GPP files
- ModifiableScheduledTask: finds scheduled tasks with weak ACLs
- ModifiableServiceBinaries: finds services whose binaries can be replaced
- ModifiableServiceRegistryKeys: finds services with writable registry keys
- ModifiableServices: finds services with weak service-level ACLs

The parent process for all SharpUp invocations was Beanie-PrintDriver.exe — confirming dropper → tool chain.

IoCs observed at this stage:

Type	Indicator
FILE	Beanie-PrintDriver.exe (dropper parent)
FILE	AppData\Local\Temp\SharpUp.exe
CMD	SharpUp.exe -AlwaysInstallElevated
CMD	SharpUp.exe -CachedGPPPassword
CMD	SharpUp.exe -DomainGPPPassword
CMD	SharpUp.exe -ModifiableScheduledTask
CMD	SharpUp.exe -ModifiableServiceBinaries
CMD	SharpUp.exe -ModifiableServiceRegistryKeys
CMD	SharpUp.exe -ModifiableServices

Stage 06 — Lateral Movement — Trojanised Network Share [T1021.002](#) · [T1080](#)

At 07:52:33, the rogue liam.espinoza account executed CapItAll-Sales-Installer.exe from the internal IT share \\ITServe\Installers\.

The installer was spawned as a child of PowerShell (powershell.exe), indicating a scripted deployment rather than manual GUI execution.

Within 16 minutes, three additional Sales-team workstations ran the same trojanised installer:

win-3453 (kyra.flores), win-3451 (miguel.odonnell), win-3452 (cain.omoore)

This confirms the attacker poisoned the trusted internal software distribution share, allowing rapid lateral spread without further phishing.

Detection gap: win-3453 had no Sysmon telemetry — the lateral movement event was inferred from network flow data only.

IoCs observed at this stage:

Type	Indicator
FILE	CapItAll-Sales-Installer.exe (trojanised)
PATH	\\ITServe\Installers\ (poisoned share)
HOST	win-3453 / kyra.flores
HOST	win-3451 / miguel.odonnell
HOST	win-3452 / cain.omoore
CMD	PowerShell Test-Path / Start-Process pattern

Stage 07 — Collection — Security Infrastructure Access [T1005](#)

The final observed stage was targeted HTTP access to security-critical internal URLs from win-3449 (Patient Zero), suggesting the attacker used the initial beachhead to harvest sensitive data.

siem.platform.com/dashboard/tryhatme — direct access to the SIEM dashboard, potentially to observe detection rules, alert status, and ongoing analyst activity.

security.tryhatme.com/logs — access to internal security logs, potentially to understand logging gaps and avoid triggering alerts.

inventory.tryhatme.com/reorders — access to inventory/procurement data, possibly for business-impact intelligence.

All three URLs were accessed via the C2-compromised host, meaning the traffic may have been proxied through 178.92.220.140:8090.

SIEM access by the adversary represents a significant operational security risk — the attacker may know which detections are active.

IoCs observed at this stage:

Type	Indicator
URL	siem.platform.com/dashboard/tryhatme
URL	security.tryhatme.com/logs
URL	inventory.tryhatme.com/reorders
HOST	10.1.3.194 / win-3449 (access origin)
IP	178.92.220.140:8090 (likely proxy)

4. Blast Radius

Hostname	IP	User	Dept	Notes
win-3449	10.1.3.194	Yani Zubair	IT	Patient Zero — phishing, C2, SIEM access
win-3454	10.1.3.129	liam.espinosa (rogue)	Sales	Rogue acct, dropper, SharpUp, lateral mvmt
win-3453	N/A	kyra.flores	Sales	Lateral (share) — no Sysmon coverage
win-3451	N/A	miguel.odonnell	Sales	Lateral (share)
win-3452	N/A	cain.omoore	Sales	Lateral (share)
Unknown	10.1.3.27	—	—	C2 beaconing host
Unknown	10.1.3.36	—	—	C2 beaconing host
Unknown	10.1.3.66	—	—	C2 beaconing host

5. Full Indicators of Compromise

Type	Indicator	Description	Stage(s)
IP	178.92.53.38	Malware delivery server (port 80)	Stages 01,02
IP	178.92.220.140	C2 server (port 8090, unknown-tcp)	Stages 04,07
DOMAIN	beanie-print-driver.thm	SEO-poisoned payload delivery domain	Stage 01
DOMAIN	googl.com	Blocked redirect/backup C2	Stage 01
URL	siem.platform.com/dashboard/tryhatme	SIEM dashboard — attacker accessed	Stage 07
URL	security.tryhatme.com/logs	Security log portal — attacker accessed	Stage 07
URL	inventory.tryhatme.com/reorders	Inventory system — attacker accessed	Stage 07
FILE	Beanie-PrintDriver.exe	Primary dropper	Stages 01,05
FILE	SharpUp.exe	PrivEsc enum tool (AppData\Local\Temp\)	Stage 05
FILE	CapItAll-Sales-Installer.exe	Trojanised Sales installer (\\ITServe\Installers\)	Stage 06
ACCT	TRYHATME\liam.espinoza	Rogue domain account	Stages 03–06
HOST	win-3454 / 10.1.3.129	Rogue actor primary workstation	Stages 03–06
HOST	win-3449 / 10.1.3.194	Patient Zero	Stages 01–04,07
HOST	10.1.3.27	C2 beaconing host	Stage 04
HOST	10.1.3.36	C2 beaconing host	Stage 04
HOST	10.1.3.66	C2 beaconing host	Stage 04
EMAIL	oskar@hatemporium.com	Phishing sender	Stage 01
EMAIL	buckley@gmail.com	Phishing sender (secondary)	Stage 01
PATH	\\ITServe\Installers\	Poisoned internal share	Stage 06

6. Splunk Detection Queries

Q1 — Initial Payload Download (Patient Zero)

```
index=main | spath input=_raw | search datasource="proxy_logs" dest_url="*beanie-print-driver*" OR dest_ip="178.92.53.38" | table _time src_ip src_user dest_url dest_ip status
```

Q2 — C2 Beaconing (port 8090)

```
index=main | spath input=_raw | search datasource="network_logs" dest_ip="178.92.220.140" dest_port=8090 | stats count by src_ip src_user _time | sort -count
```

Q3 — SharpUp Execution

```
index=main | spath input=_raw | search datasource="sysmon_logs" process_name="SharpUp.exe" | table _time host user process_name process_args parent_process
```

Q4 — Rogue Account Activity (liam.espinoza)

```
index=main | spath input=_raw | search datasource="sysmon_logs" user="liam.espinoza" OR user="TRYHATME\\liam.espinoza" | table _time host user process_name process_args
```

Q5 — Anti-Forensic PowerShell Commands

```
index=main | spath input=_raw | search datasource="sysmon_logs"  
process_name="powershell.exe" (process_args="*Remove-Item*Temp*" OR  
process_args="*Start-Service*wuauserv*") | table _time host user process_args
```

Q6 — Trojanised Installer Lateral Movement

```
index=main | spath input=_raw | search datasource="sysmon_logs"  
process_name="CapItAll-Sales-Installer.exe" OR (process_args="*CapItAll*" AND  
process_name="powershell.exe") | table _time host user process_name parent_process
```

Q7 — SIEM/Security Infrastructure Access

```
index=main | spath input=_raw | search datasource="proxy_logs"  
(dest_url="*siem.platform.com*" OR dest_url="*security.tryhatme.com*" OR  
dest_url="*inventory.tryhatme.com*") | table _time src_ip src_user dest_url status
```

Q8 — All Hosts Communicating with Attacker IP Range

```
index=main | spath input=_raw | search datasource="network_logs"  
(dest_ip="178.92.53.38" OR dest_ip="178.92.220.140") | stats count by src_ip dest_ip  
dest_port | sort -count
```

Q9 — Beanie-PrintDriver Dropper Execution (All Hosts)

```
index=main | spath input=_raw | search datasource="sysmon_logs"  
process_name="Beanie-PrintDriver.exe" | table _time host user process_name  
parent_process
```

7. MITRE ATT&CK Mapping

TTP ID	Technique	Tactic	Stage
T1566.001	Phishing: Spearphishing Attachment	Initial Access	Stage 01
T1189	Drive-by Compromise (SEO poisoning)	Initial Access	Stage 01
T1059.001	Command and Scripting Interpreter: PowerShell	Execution	Stage 02
T1070.004	Indicator Removal: File Deletion	Defense Evasion	Stage 02
T1036	Masquerading (wuaucflt.exe LOLBin)	Defense Evasion	Stage 02
T1136.001	Create Account: Local/Domain Account	Persistence	Stage 03
T1571	Non-Standard Port (8090)	Command and Control	Stage 04
T1095	Non-Application Layer Protocol (unknown-tcp)	Command and Control	Stage 04
T1068	Exploitation for Privilege Escalation	Privilege Escalation	Stage 05
T1021.002	Remote Services: SMB/Windows Admin Shares	Lateral Movement	Stage 06
T1080	Taint Shared Content	Lateral Movement	Stage 06
T1005	Data from Local System	Collection	Stage 07

8. Remediation & Containment

IMMEDIATE (0–4 hrs)

- Isolate win-3449, win-3454, win-3451, win-3452, win-3453 from the network
- Block 178.92.220.140 and 178.92.53.38 at perimeter firewall and DNS sinkhole
- Disable TRYHATME\liam.espinosa in Active Directory and reset all session tokens
- Quarantine CapItAll-Sales-Installer.exe from \\ITServe\Installers\ and lock the share
- Revoke access to siem.platform.com / security.tryhatme.com from all endpoints pending review

SHORT-TERM (4–48 hrs)

- Reimage all confirmed-compromised endpoints (win-3449, win-3454 at minimum)
- Audit all accounts created in the last 30 days in Active Directory
- Deploy Sysmon to win-3453 and any endpoint missing telemetry coverage
- Rotate credentials for IT and Sales department users
- Review and harden \\ITServe\Installers\ ACLs — restrict write access to IT admin accounts only

LONG-TERM (1–4 weeks)

- Implement egress filtering to block non-standard ports (8090, etc.) by default
- Enable SIEM alerting on SharpUp / PowerUp signatures and LOLBin abuse patterns
- Conduct phishing awareness training targeting the spear-phish vector used
- Perform threat hunt across all endpoints for Beanie-PrintDriver.exe hash artifacts
- Review SIEM dashboard access controls — consider IP allowlisting for the dashboard

9. Detection Gaps

- win-3453 (kyra.flores) has no Sysmon coverage — lateral movement was inferred from network flow only. Deploy Sysmon immediately.
- 3 C2 beaconing hosts (10.1.3.27, .36, .66) remain unidentified — no Sysmon or asset inventory match found.
- The initial phishing email was not caught by the email gateway; SEO-poisoned domain was not in threat-intel blocklists.
- SharpUp execution was not alerted in real-time — no behavioural rule existed for known PrivEsc tool signatures.
- Non-standard port 8090 (unknown-tcp) egress was not blocked or alerted at the firewall.